Politique de contrôle d'accès et de gestion des identités

Organisation	Carthago FinTech (organisation fictive, étude de cas pédagogique)
Référence	ACC-POL-01
Version	1.0 — octobre 2026
Statut	Projet soumis à approbation
Propriétaire	Responsable de la sécurité des systèmes d'information (CISO)
Approbation	Direction générale (CEO)
Prochaine revue	Octobre 2027, ou après tout incident majeur touchant les identités
Risques traités	R-01, R-02, R-03, R-04
Contrôles ISO/IEC 27001:2022, Annexe A	A.5.15, A.5.16, A.5.17, A.5.18, A.8.2, A.8.5

> Les valeurs chiffrées de cette politique (délais, fréquences) sont des propositions de départ à valider avec la Direction et les équipes concernées.

1. Objet

Cette politique définit comment Carthago FinTech attribue, protège, contrôle et retire les accès à ses systèmes d'information. Elle vise à ce que chaque personne ou service dispose uniquement des droits nécessaires, pendant la durée nécessaire, et que ces droits soient démontrables.

2. Périmètre

Elle s'applique à toutes les identités du périmètre du SMSI : collaborateurs, consultants et prestataires externes, comptes d'administration, comptes de service et comptes de secours. Elle couvre Microsoft Entra ID, les abonnements Azure, GitLab, les outils de sécurité (Sentinel, Defender) et les applications d'entreprise utilisant l'authentification unique.

3. Principes

1. **Moindre privilège** : chaque identité reçoit le minimum de droits pour sa mission.
2. **Besoin d'en connaître** : l'accès aux données sensibles est limité aux personnes qui en ont l'usage.
3. **Séparation des tâches** : les fonctions incompatibles ne sont pas réunies sur une même identité.
4. **Traçabilité** : toute attribution de droit et tout accès privilégié laissent une trace exploitable.
5. **Limitation dans le temps** : les droits sensibles sont temporaires ou revus régulièrement.

4. Rôles et responsabilités

Rôle	Responsabilités
Direction générale (CEO)	Approuve la politique et les exceptions de niveau élevé
CISO	Propriétaire de la politique, contrôle de son application, revue des droits privilégiés
CIO	Met en œuvre les mécanismes techniques (Entra ID, Azure, accès conditionnel, PAM)
CTO	Applique la politique aux comptes de service, aux secrets et aux dépôts de code
Managers	Demandent et confirment les droits de leur équipe, déclenchent les mobilités et les départs
Propriétaires d'application	Attestent les droits de leur application lors des revues
Ressources humaines	Notifient les arrivées, mobilités et départs dans les délais
Collaborateurs et prestataires	Protègent leurs moyens d'authentification et signalent toute anomalie

5. Règles

5.1 Cycle de vie des identités

N°	Règle
ACC-01	Toute identité a un propriétaire nommé et une date de fin ou de revue.
ACC-02	À l'arrivée, les droits standards sont attribués selon le département. Les droits complémentaires sont approuvés par le manager, et par le propriétaire de l'application ou le CISO pour les systèmes sensibles.

ACC-03	Lors d'une mobilité, les droits de l'ancienne fonction sont retirés dans les 5 jours ouvrés suivant le changement, et le manager confirme les droits à conserver.
ACC-04	Au départ, les comptes sont désactivés au plus tard à l'heure de fin de contrat ; les sessions et les jetons actifs sont révoqués.
ACC-05	Les comptes d'externes ont une date de fin obligatoire alignée sur la fin de mission. Une prolongation est approuvée par le responsable interne ; sans prolongation, le compte est désactivé automatiquement à l'échéance.

5.2 Authentification

N°	Règle
ACC-06	L'authentification multifacteur (MFA) est obligatoire pour tous les comptes humains. Toute exception technique est enregistrée, justifiée, approuvée par le CISO et revue chaque trimestre.
ACC-07	Les comptes d'administration utilisent une méthode MFA résistante au phishing ou, à défaut, une approbation avec saisie du numéro affiché. Toute demande MFA non sollicitée est signalée immédiatement à l'équipe sécurité et n'est jamais approuvée.
ACC-08	Un mot de passe n'est jamais partagé ni saisi en dehors des pages de connexion officielles. Un mot de passe soupçonné d'être compromis est changé immédiatement et signalé.

5.3 Comptes privilégiés

N°	Règle
ACC-09	Les droits privilégiés sont attribués à la demande, pour une durée limitée et avec approbation, plutôt que de façon permanente. Seuls les comptes de secours restent permanents ; ils sont contrôlés et testés.
ACC-10	Chaque administrateur utilise un compte dédié, distinct de son compte quotidien, sans boîte de messagerie.
ACC-11	Les rôles transverses entre environnements (développement, test, préproduction, production) sont interdits. En cas d'urgence, une exception documentée, limitée dans le temps et revue après usage est requise.
ACC-12	Les droits privilégiés sont revus chaque trimestre par le CISO et le CIO.

5.4 Comptes de service et secrets

N°	Règle
ACC-13	Les secrets sont stockés dans le coffre de secrets, jamais dans le code ni dans les dépôts. Ils font l'objet d'une rotation planifiée ; les identités managées sont privilégiées quand elles existent.
ACC-14	Chaque compte de service a un propriétaire, un périmètre minimal et une date de dernière rotation enregistrée.

5.5 Revue des droits

N°	Règle
ACC-15	Les droits sont revus tous les 6 mois pour les systèmes critiques et chaque année pour les autres systèmes. Les résultats sont consignés et les écarts corrigés sous 10 jours ouvrés.
ACC-16	Les propriétaires d'application attestent les droits de leur périmètre. L'absence de réponse dans les délais est escaladée au CISO.

5.6 Journalisation et supervision

N°	Règle
ACC-17	Les événements d'authentification, d'attribution de droits et d'activité d'administration sont journalisés et transmis au SIEM. La liste des sources est revue à chaque changement d'architecture.
ACC-18	Les situations suivantes déclenchent une alerte traitée selon la procédure de gestion des incidents : connexion d'un compte privilégié dans un contexte inhabituel, refus MFA répétés, attribution d'un rôle privilégié.

5.7 Accès à distance

N°	Règle
ACC-19	Les accès à distance et les fonctions d'administration sont soumis à des politiques d'accès conditionnel (appareil conforme, localisation, niveau de risque de la connexion).

6. Exceptions

Toute dérogation à cette politique est demandée par écrit, justifiée, approuvée par le CISO (par le CEO pour les droits privilégiés), limitée à 90 jours renouvelables et enregistrée dans un registre des exceptions revu chaque trimestre.

7. Mesure de l'application

Indicateur	Règles concernées
KPI-01 Couverture MFA des comptes humains	ACC-06, ACC-07
KPI-02 Délai de désactivation après départ ou fin de mission	ACC-04, ACC-05
KPI-03 Revues d'accès réalisées dans les délais	ACC-12, ACC-15, ACC-16
KPI-04 Couverture des sources de logs critiques	ACC-17

8. Non-respect et révision

Le non-respect de cette politique peut entraîner des mesures prévues par le règlement interne et les contrats applicables. La politique est revue au moins une fois par an et après tout incident majeur touchant les identités.

Annexe — Traçabilité

Règles	Écarts traités	Risques	Contrôles Annexe A	Actions du plan
ACC-01, ACC-14	IAM-07	R-04	A.5.16, A.5.17	T-12
ACC-02	IAM-01	R-03	A.5.18	T-10
ACC-03	IAM-01	R-01, R-03	A.5.18	T-10
ACC-04, ACC-05	IAM-09	R-03	A.5.16, A.5.18	T-10
ACC-06	IAM-05	R-01	A.8.5	T-02
ACC-07, ACC-08	IAM-06, HUM-01	R-01	A.8.5, A.5.17	T-02, T-05
ACC-09, ACC-10	IAM-03, IAM-04	R-01	A.8.2	T-01, T-04
ACC-11	IAM-03, CLD-03	R-01	A.8.2, A.5.3, A.8.31	T-01
ACC-12, ACC-15, ACC-16	IAM-02	R-01, R-03	A.5.18, A.8.2	T-03, T-11
ACC-13	IAM-07, DEV-04	R-04	A.5.17, A.8.24	T-12, T-13
ACC-17, ACC-18	IAM-08, SOC-01	R-02	A.8.15, A.8.16	T-06, T-07
ACC-19	IAM-06	R-01	A.5.15, A.8.5	T-02